



TORIN
CYBER GROUP

AI DATA SPILL INCIDENT RESPONSE KIT

TABLETOP EXERCISE WORKBOOK



PREPARE
Understand the scenario



RESPOND
Make critical decisions



COLLABORATE
Work as a team



IMPROVE
Take action back at work

SHANNA DALY
CEO, TORIN CYBER GROUP
VERSION 1.3 | 7 AUGUST 2026

PREPARE | RESPOND | RECOVER | IMPROVE

CONTENTS

Before we start.....	3
Ground rules.....	3
The five lenses	3
Exercise Objectives.....	3
What is an AI data spill?	4
The Incident Response Lifecycle	6
Planning & Testing	7
What is a tabletop exercise?	7
Why do organisations run tabletop exercises?	7
Different types of tabletop exercises	7
What makes a good tabletop?.....	8
INJECT 1 The report.....	9
INJECT 2 What was in it.....	11
INJECT 3 Loss of control.....	13
INJECT 4 The obligation.....	15
INJECT 5 The decision	17
INJECT 6 What the provider says	19
INJECT 7 Closing the incident	21
Hot wash.....	23
Where Does your Organisation stand?	25
1. Strengthen governance	25
2. Protect our data	25
3. Build awareness and capability	26
4. Improve detection and response	26
5. Drive continuous improvement	26
Ten questions For Monday	27
What's next.....	28
Privacy and notification	28
Cyber security guidance	28
Sector-specific	29
Frameworks	29

BEFORE WE START

This is a learning exercise, not a test.

There are no right or wrong answers today, and nobody is keeping score. The value comes from the discussion. Everyone in the room has a different perspective, whether that's based on their role, their organisation or their experience. If you've got an idea, put it on the table. You don't need to have the complete answer for it to be useful.

GROUND RULES

- > **Be respectful.** Everyone brings a different perspective.
- > **Take part.** Your ideas don't have to be perfect to be useful.
- > **Challenge assumptions.** Ask questions and explore different options.
- > **Explain your thinking.** It helps everyone understand your reasoning.
- > **Accept uncertainty.** You won't have every fact, just like a real incident.
- > **No blame.** The goal is to learn, not to find fault.

THE FIVE LENSES

As we work through today's scenario, we'll look at the incident through five different lenses. Each lens brings a different perspective, asks different questions and has different priorities. As the discussion unfolds, think about how each group would view the situation and what they would need to make decisions.

LENS	FOCUS
Security / IT	What happened? How do we contain it and understand the technical impact?
Privacy	Does this involve personal information, and what obligations might apply?
Legal	What are the legal, contractual and regulatory considerations?
Communications	Who needs to know, what should we say, and when should we say it?
Leadership	What decisions need to be made, and what are the broader business impacts?

EXERCISE OBJECTIVES

By the end of today's session, you will be able to:

- > Recognise an AI data spill.
- > Make incident response decisions.
- > Consider privacy, legal and business impacts.
- > Identify improvements to take back to work.



WHAT IS AN AI DATA SPILL?

An AI data spill occurs when sensitive or confidential information is entered into an AI system outside an organisation's approved controls.

The risk isn't just that the information has been exposed. It's that the organisation may no longer know where it is, who can access it, or how it will be used.

For today's exercise, AI refers to generative AI assistants such as ChatGPT, Microsoft Copilot, Gemini and Claude.

REFLECTION QUESTIONS

1. What types of information would be considered sensitive in your organisation?

2. Which AI tools are approved for use in your organisation?

3. What information would you never be comfortable entering into an AI assistant? Why?

4. If an employee accidentally uploaded sensitive information to an AI tool today, would they know who to report it to?

☐ Yes ☐ No ☐ Not sure



5. Before today, had you thought about an AI data spill as an incident that might require an incident response?

☐ Yes ☐ No

Why or why not?

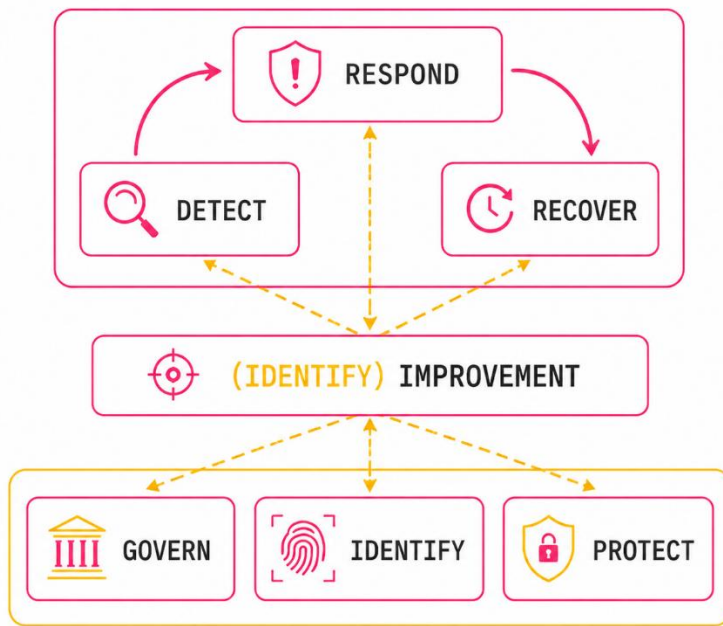


THE INCIDENT RESPONSE LIFECYCLE

The NIST Incident Response Lifecycle provides a structured approach to managing cyber security incidents. It helps organisations respond consistently, reduce impacts and continuously improve their security posture.

Incident response is not a single action. It is a cycle of detecting an issue, responding to it, recovering from the impact and using what was learned to improve the organisation's wider controls.

During today's exercise, consider where each decision sits within the lifecycle.



DETECT

- > How was the incident identified?
- > What signs, reports or alerts would help your organisation recognise an AI data spill?

RESPOND

- > What needs to happen first?
- > Who should be involved, and what decisions need to be made?

RECOVER

- > What needs to happen before normal operations can resume?
- > What ongoing risks or actions might remain after the immediate response?

REFLECTION QUESTIONS

6. Which stage of the lifecycle do you feel most confident you could contribute to? Why?

7. Which stage do you think is the most important? Why?



PLANNING & TESTING

WHAT IS A TABLETOP EXERCISE?

A tabletop exercise (TTX) is a discussion-based activity where participants work through a realistic scenario and decide how they would respond.

Unlike a technical simulation, a tabletop isn't about using tools or following detailed procedures. It's about thinking through a situation, asking the right questions and understanding how different parts of the organisation work together.

During a tabletop, the scenario unfolds over time. As new information becomes available, participants discuss what they know, what they need to find out and what actions they would take next.

WHY DO ORGANISATIONS RUN TABLETOP EXERCISES?

Organisations don't wait for a real incident to discover whether their plans work.

Tabletop exercises help teams:

- > Practise responding before a real incident occurs.
- > Understand roles and responsibilities.
- > Improve communication and decision-making.
- > Test plans, processes and assumptions.
- > Identify gaps before they become problems.

Like emergency drills in aviation, healthcare or emergency services, the goal is to build confidence before you're responding under pressure.

DIFFERENT TYPES OF TABLETOP EXERCISES

Tabletop exercises can be run for almost any type of incident, including:

- > Cyber security incidents
- > Data breaches and privacy incidents
- > AI data spills
- > Ransomware attacks
- > Business continuity events
- > Natural disasters
- > Insider threats
- > Third-party or supply chain incidents

Some exercises focus on technical response, while others explore executive decision-making, communications or crisis management.



WHAT MAKES A GOOD TABLETOP?

A good tabletop doesn't measure how much you know.

It encourages discussion, explores different perspectives and helps people understand how they would work together during an incident.

The most valuable outcomes are often the questions participants ask, the assumptions they challenge and the improvements they identify.

REFLECTION QUESTIONS

8. Have you participated in a tabletop exercise before?

☐ Yes ☐ No

9. What do you hope to get out of today's exercise?



INJECT 1 THE REPORT

WHAT'S NEW

- > Monday, 8:15 am. The IT Service Desk takes a call from Emma, a senior analyst who has been with the organisation six years. She is well regarded, performs strongly and has never been involved in a security incident.
- > Over the weekend Emma was finalising a board paper for Monday morning's executive meeting, working to a deadline.
- > On Sunday evening she uploaded a large spreadsheet to a free public AI assistant to summarise it. It is a tool she uses at home for personal tasks.
- > Afterwards she realised she had put organisational information into a tool that is not approved for work use.
- > She waited until the Service Desk opened on Monday morning to report it.

INCIDENT QUESTIONS

10. Is this a security incident? What makes you say so?

11. What are the first three things you would do?

12. What information do you need to gather, and who would you get it from?

13. Who should be told now, and who should not be told yet? Why?



14. If this happened at your organisation, would the person know who to call? Would there have been anyone to call on a Sunday evening?



INJECT 2 WHAT WAS IN IT

WHAT'S NEW

- > Monday, 10:30 am. The Service Desk escalates the matter to the security operations team.
- > Emma still has the spreadsheet and can show the team exactly what she uploaded.
- > The file contains current financial performance and revenue forecasts, pipeline opportunities and contract values, the status of live bids, recently won contracts not yet publicly announced, internal pricing assumptions and commercial strategy, as well as the names, job titles and contact details of key customer contacts.
- > Emma uploaded the entire file, not an extract.
- > The organisation does not yet know what the AI provider does with files that are uploaded to it.

INCIDENT QUESTIONS

15. How has your assessment of the incident changed?

16. Does anything in this file count as personal information? Does that change who needs to be involved?

17. What is the difference between this information being disclosed to the AI provider and it being made public? Which one are we dealing with?

18. Which teams should now become involved, and does that escalation path exist in your organisation?



19. What should happen in the next hour?

20. Do we have enough information to assess the impact, or are we still assuming?

21. As a table, agree a severity rating for this incident: low, medium, high or critical. Write it down. We will come back to it.



INJECT 3 LOSS OF CONTROL

WHAT'S NEW

- > Monday, 1:00 pm. The team establishes how the tool was accessed. Emma signed in using her personal email address, not her corporate account.
- > She uploaded the file from her work laptop, over her home internet connection, on a Sunday evening.
- > The service is not on any approved list. The organisation's acceptable use policy does not mention AI tools at all.
- > The organisation has no administrative access to Emma's account and no relationship of any kind with the provider.
- > Emma can show the team the conversation on her own account, but the organisation has no independent record of it and cannot confirm that nothing has been deleted or altered.
- > Nothing suggests this was deliberate. Emma reported it herself as soon as she realised.
- > Emma offers to delete the conversation straight away.

INCIDENT QUESTIONS

22. How does the use of a personal account change the response?

23. Emma has offered to delete the conversation. Do you let her? Who should make that call?

24. What should the organisation write down, screenshot or keep a copy of while it still can?



25. There is no account manager, no support contract and no legal relationship with this provider. What options does that leave you?

26. What assumptions should the team avoid making at this point?

27. How bad is this: minor, serious, or somewhere in between? What specifically makes it that bad?



INJECT 4 THE OBLIGATION

WHAT'S NEW

- > Tuesday, 9:00 am. Legal and Commercial have reviewed the file overnight.
- > Several of the customers named in the spreadsheet are covered by confidentiality clauses requiring the organisation to tell them if their confidential information is disclosed to an unauthorised third party.
- > One of those customers is due to announce a major contract award later this week.
- > Legal's advice is qualified. Whether uploading a file to an AI service counts as a disclosure to a third party has not been tested, and the answer may depend on what the provider does with the file, which the organisation still does not know.
- > Leadership asks for an urgent assessment of who needs to be told.

INCIDENT QUESTIONS

28. Has this become a legal and contractual issue rather than a technical one? What changes if it has?

29. Is uploading a file to an AI service a disclosure to a third party? Who in your organisation would decide that, and how confident would they be?

30. Who might the organisation owe an explanation to: customers, insurers, business partners, the board? Are there regulators involved, and does that depend on your industry?

31. What facts must be confirmed before anyone contacts an external party?



32. Who has the authority to decide whether a notification is made, including out of hours?

33. Look back at the severity rating your table agreed at Inject 2. Has it changed? What changed it?



INJECT 5 THE DECISION

WHAT'S NEW

- > Tuesday, 3:45 pm. The customer's contract award announcement has been brought forward to tomorrow morning.
- > It is the customer's announcement, not the organisation's. It cannot simply be delayed. The organisation can only ask the customer to hold it, which means explaining why.
- > The spreadsheet names this customer, the expected contract value, the internal pricing assumptions behind the bid and the commentary on the negotiation.
- > The customer has been told nothing so far.
- > The organisation still cannot determine whether the provider retained the file or whether anyone else has seen it and will not be able to before the announcement.

INCIDENT QUESTIONS

34. Decide now: tell the customer today, ask them to hold the announcement, or say nothing for the moment. You have three minutes and you do not get any more facts.

35. Who should have the authority to make that call?

36. Write down the first two sentences you would say to that customer on the phone.



37. What are the risks of telling them today?

38. What are the risks of waiting?

39. Would your answer change if this customer represented forty per cent of your revenue?

40. What would you tell your own executives before the customer hears anything?



INJECT 6 WHAT THE PROVIDER SAYS

WHAT'S NEW

- > Wednesday, 11:00 am. The team tries to establish what the provider does with uploaded files.
- > Because Emma signed up with a personal account, there is no support agreement, no account manager and no legal relationship. All the team has is the same public Terms of Service and Privacy Policy that anyone can read.
- > Those documents indicate that uploaded prompts and files may be retained, and that deleting a conversation may not immediately remove it from backup systems.
- > Whether submitted content is used to improve the service depends on the account type and the settings in use. Free and personal accounts are commonly treated differently from business and enterprise accounts.
- > The organisation has no way to verify how Emma's account was configured at the time of the upload.
- > The conversation has already been deleted from Emma's account. Nobody formally authorised it.

INCIDENT QUESTIONS

41. The conversation has been deleted, and nobody authorised it. Should that have happened, and who should have made that decision?

42. Does deleting the conversation resolve the incident?

43. What evidence can the organisation actually rely on now?



44. What assumptions should you avoid making?

45. Is the uncertainty itself a business risk? How would you describe that risk to your chief executive in one sentence?

46. Would your response have been different if this had been an approved enterprise AI platform? What specifically would have changed?

47. Without Emma telling you, would your organisation have detected this at all?



INJECT 7 CLOSING THE INCIDENT

WHAT'S NEW

- > The following week. Whatever your group decided at Inject 5, the scenario now proceeds as follows.
- > The affected customer was told before the announcement, in line with the contractual obligation.
- > The organisation has found no evidence of any further access to the information, though it has no means of detecting it had there been any.
- > It cannot confirm whether the uploaded content was used to improve the AI service.
- > Leadership considers the immediate operational response complete.
- > During the review, two further uploads to public AI tools come to light. Neither was reported at the time.

INCIDENT QUESTIONS

48. Can this incident be closed? What would closed mean here?

49. What residual risk is the organisation accepting, and who is accepting it on the organisation's behalf?

50. What did the organisation do well? What would you have done differently?

51. Two other people did the same thing and said nothing. What does that tell you, and what would you do about it?



52. Should there be any consequences for Emma? What does your answer tell the next person who makes a mistake?

53. What has this incident cost the organisation, even though nothing was leaked?



HOT WASH

A hotwash is a short debrief held straight after an exercise, while the discussion is still fresh. The aim is to capture what stood out, what worked, what caused uncertainty and what should change. It is not about judging individual decisions or finding fault. The value comes from being specific about where the response was clear and where people had to rely on assumptions.

Use the questions below to reflect on the exercise and identify practical improvements.

REFLECTION QUESTIONS

54. What was your biggest takeaway from today's exercise?

55. Was there anything that surprised you?

56. What question do you want to take back to your organisation?

57. What is one thing your organisation is already doing well?

58. What is one area that could be improved?



59. Something someone else said that I hadn't considered...

A NOTE ON THE PERSON, NOT THE PROCESS

Emma had six years of service, a strong record and no history of security incidents. She was working late on a board paper under deadline pressure and used a tool that made her job easier. No control in the scenario would have stopped her, and no amount of training would reliably prevent every version of that decision.

The lesson of this exercise is not that organisations need to catch Emma. It is that they need to build the conditions in which Emma never had to make that choice alone — an approved tool that worked, a clear rule she'd actually seen, and enough psychological safety that when she got it wrong, her first instinct was to pick up the phone.



WHERE DOES YOUR ORGANISATION STAND?

The exercise may be over, but the conversation shouldn't stop here. Use this self-assessment when you're back at work to reflect on your organisation's current approach to AI. The goal is to identify practical actions you can take, whether that's updating a policy, improving awareness or starting a conversation with the right people.

1. STRENGTHEN GOVERNANCE

WHERE ARE WE?	Not yet	Partly	Mostly	Done
We have a written position on AI use that staff have read.				
We maintain a list of AI tools that are approved, and a way to request new ones.				
Someone is clearly accountable for AI governance — by name, not by committee.				
Our acceptable use policy explicitly addresses uploading information to AI services.				
AI risk appears somewhere on a risk register that leadership reviews.				

2. PROTECT OUR DATA

WHERE ARE WE?	Not yet	Partly	Mostly	Done
Our information is classified well enough that staff know what must not leave.				
We have controls that would restrict or flag uploads to unapproved AI services.				
We provide an approved AI tool that is good enough that staff don't need to go elsewhere.				
Where we use enterprise AI, we know its retention, training and deletion terms.				
Contractual confidentiality obligations to our customers are documented and findable.				



3. BUILD AWARENESS AND CAPABILITY

WHERE ARE WE?	Not yet	Partly	Mostly	Done
Staff have been told what is and isn't acceptable to put into an AI tool.				
People understand the difference between a consumer and an enterprise AI account.				
Staff know how to report a mistake and believe they won't be punished for it.				
Managers know what to do when someone reports something like this to them.				
Awareness content is current — written in the last twelve months.				

4. IMPROVE DETECTION AND RESPONSE

WHERE ARE WE?	Not yet	Partly	Mostly	Done
We could detect an upload to an unapproved AI service without being told.				
Our incident response plan contemplates a data spill with no forensic certainty.				
We know who has authority to approve a customer notification, out of hours.				
We have a decision path for acting on incomplete information.				
Legal, Comms and Leadership have practised working together on an incident.				

5. DRIVE CONTINUOUS IMPROVEMENT

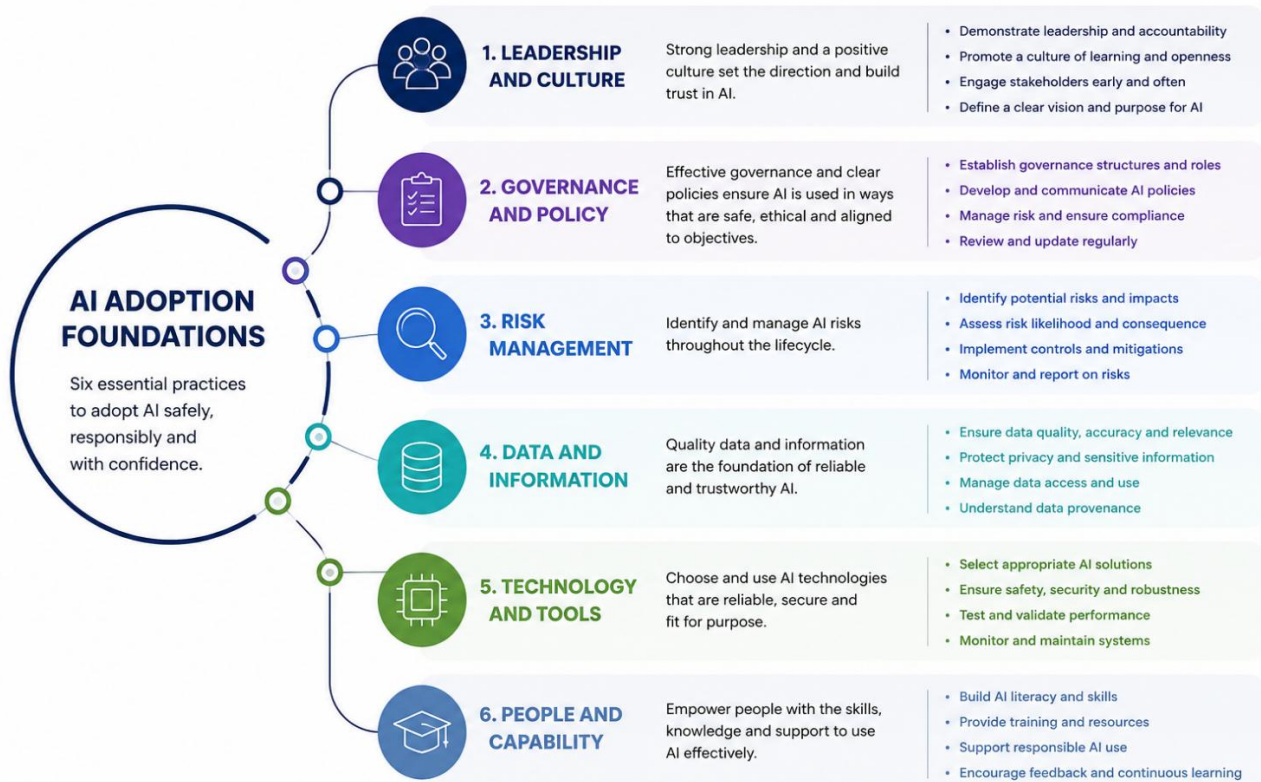
WHERE ARE WE?	Not yet	Partly	Mostly	Done
We exercise our incident response plan at least annually.				
Post-incident reviews produce actions with owners and dates.				
We revisit those actions to confirm they were actually done.				
Near misses are captured, not just incidents.				
Lessons from one incident change how we behave, not just what our documents say.				



TEN QUESTIONS FOR MONDAY

Every organisation is on a different path with AI. Some have mature governance, approved platforms and well-tested response plans. Others are still working out where to begin.

1. Which AI tools are being used across our organisation today, and how do we know?
2. Do we provide approved AI tools that people genuinely want to use, or are employees finding their own alternatives?
3. What types of information can and can't be entered into an AI assistant, and would our people know the difference?
4. If someone uploaded sensitive information to a public AI tool this afternoon, how would we detect it?
5. Do we understand how our approved AI platforms handle uploaded information, including retention, model training and deletion?
6. Who would need to be involved if an AI data spill occurred tomorrow? Would everyone know their role?
7. If we couldn't determine exactly what happened to the uploaded information, would our incident response process still work?
8. If an employee made Emma's mistake tomorrow, would they report it immediately? What does that say about our culture?
9. When was the last time we practised responding to a cyber or data incident with Security, Privacy, Legal, Communications and Leadership involved?
10. If this incident happened here tomorrow, what is the first thing we would change after it was over?





WHAT'S NEXT

Today's exercise was designed to introduce the concepts behind AI data spills and incident response. If you'd like to explore the topic further, the resources below are a good place to start. They provide practical guidance on privacy, cyber security, AI governance and incident response in an Australian context.

Every organisation is different. The laws, regulations and contractual obligations that apply to you will depend on your industry, the information involved and the circumstances of an incident.

PRIVACY AND NOTIFICATION

OFFICE OF THE AUSTRALIAN INFORMATION COMMISSIONER

Start with the OAIC's guidance on the Notifiable Data Breaches scheme. It explains how to assess a suspected eligible data breach, when notification may be required and the expectation that assessments be completed as quickly as practicable and, where possible, within 30 calendar days.

The OAIC also publishes guidance on using commercially available AI products. It covers due diligence, privacy impact assessments, personal information used as AI input, transparency, retention and access by AI providers. The OAIC recommends that organisations avoid entering personal information, particularly sensitive information, into publicly available generative AI tools.

PRIVACY ACT 1988 AND THE 2024 REFORMS

Review the Privacy Act 1988 together with the Privacy and Other Legislation Amendment Act 2024. The reforms include changes relating to privacy enforcement, eligible data breaches and transparency about certain automated decisions. Check the commencement arrangements for the provisions relevant to your organisation rather than assuming every amendment applies immediately.

CYBER SECURITY GUIDANCE

THE AUSTRALIAN CYBER SECURITY CENTRE

ASD's ACSC publishes guidance on engaging with AI securely, including risks associated with third-party and self-hosted AI systems. Its [secure AI system development](#) guidance is more relevant to organisations building, integrating or operating AI systems and covers secure design, development, deployment and operation.

ESSENTIAL EIGHT

The Essential Eight remains a useful baseline for cyber security. Application control may help restrict unapproved software, while user application hardening reduces common application risks. These controls should be considered alongside DLP, web filtering, SaaS discovery, access controls and monitoring where the concern is public or unapproved AI services.



INFORMATION SECURITY MANUAL

The ISM contains security controls and guidance relevant to protecting sensitive information and responding when data is mishandled or exposed. Use the current version and select controls appropriate to your organisation's risks and operating environment.

SECTOR-SPECIFIC

APRA-REGULATED ENTITIES

CPS 234 requires APRA-regulated entities to maintain information security capability, implement controls and incident management arrangements, and notify APRA of certain information security incidents.

AUSTRALIAN GOVERNMENT

Australian Government entities should review the **Policy for the responsible use of AI in government** and the **National Framework for the Assurance of AI in Government**. These resources address accountable, transparent and risk-based AI use across government.

CRITICAL INFRASTRUCTURE

Owners and operators of critical infrastructure should determine whether the **Security of Critical Infrastructure Act 2018** applies to their assets. Obligations vary by asset class and may include registration, risk-management and cyber incident reporting requirements.

FRAMEWORKS

NIST SP 800-61 REVISION 3

Incident Response Recommendations and Considerations for Cyber security Risk Management. This publication integrates incident response into wider cyber risk management and aligns its recommendations with the NIST Cybersecurity Framework 2.0.

NIST CYBER SECURITY FRAMEWORK 2.0

The six cyber security framework core functions are Govern, Identify, Protect, Detect, Respond and Recover. Together they provide a practical structure for considering prevention, preparation, response and improvement.

ISO/IEC 42001:2023

An international management system standard for organisations that develop, provide or use AI systems. It sets requirements for establishing, operating and continually improving an AI management system.



TORIN CYBER GROUP

Thank you for taking part. If this exercise raised something you'd like to work through properly, we run these for individual organisations with your own people in the room.

www.torincyber.com

